

CRIPTOGRAFÍA • UNIDAD 3

Cifrado asimétrico, hash y firma digital

Enfoque práctico basado en los capítulos 3 y 4 de Cryptography Algorithms, 2.^a edición (acceso anticipado), Massimo Bertaccini, Packt, 2024

AGENDA

Contenidos de la sesión

- | | | | |
|-----------|---|-----------|---|
| 01 | El problema de distribución de claves Por qué el cifrado simétrico no podía escalar por sí solo | 02 | Intercambio de claves Diffie-Hellman Secretos compartidos y ataque de intermediario |
| 03 | RSA en la práctica Claves, ataques, relleno y un caso de verificación de tratados | 04 | PGP y ElGamal Protocolos híbridos y aleatoriedad efímera |
| 05 | Funciones hash Propiedades, familia SHA y recorrido por SHA-1 | 06 | Firmas digitales y firmas ciegas RSA, ElGamal y el protocolo ciego de Chaum |

RESULTADOS DE APRENDIZAJE

Al finalizar la sesión podrá...

- Explicar qué problema resuelve el cifrado asimétrico y por qué no podía resolverse con mensajeros y claves compartidas
- Explicar qué aporta cada algoritmo y cuáles son sus límites
- Reconocer dónde falla cada algoritmo: ataque de intermediario, factorización, exponentes cortos y colisiones
- Justificar dos hábitos que protegen los sistemas reales: agregar relleno al mensaje y firmar el hash, nunca el mensaje
- Describir cómo los protocolos híbridos, como PGP, combinan transporte asimétrico de claves con cifrado simétrico de datos

01

CAPÍTULO 3

Cifrado asimétrico

Diffie-Hellman · RSA · PGP · ElGamal y los ataques que impulsaron su evolución

EL PROBLEMA

Antes de 1976: claves por mensajería

- El cifrado simétrico requiere la misma clave en ambos extremos, por lo que la clave debe entregarse
- COMSEC de Estados Unidos, responsable de transmitir claves, movilizaba toneladas de ellas cada día
- En la década de 1970, los bancos enviaban las claves DES mediante mensajeros que las entregaban personalmente
- La NSA, con los mejores recursos de cómputo del mundo, no pudo resolver la distribución; RAND tampoco

LA PREGUNTA

Si dos desconocidos se encuentran en Internet, ¿cómo pueden cifrar un documento compartido sin intercambiar nada distinto del propio documento?

Ese es, en esencia, el problema del intercambio de claves.

DEFINICIÓN

Dos claves diferentes, una operación para cada una

CLAVE PÚBLICA

Se publica para todos. Cualquier persona puede usarla para proteger un mensaje dirigido a usted.

CLAVE PRIVADA

Permanece con el propietario. Es la única que puede recuperar el mensaje.

- Cifrado asimétrico = un par de claves distintas para cifrar y descifrar
- Su uso cotidiano protege tarjetas de crédito, cuentas en línea, contraseñas y datos privados en tránsito
- Consecuencia esencial: cuando Bob cifra con la clave pública de Alice, ni siquiera Bob puede descifrar el mensaje

UNA DISTINCIÓN IMPORTANTE

Clave pública/privada $\neq$ algoritmo asimétrico

Ejemplo de claves pública y privada: Diffie-Hellman

- Produce una clave compartida, no un texto cifrado
- Después, el mensaje se cifra de forma simétrica con AES
- Ambas partes deben participar antes de enviar información

Ejemplos asimétricos: RSA y ElGamal

- Cifran directamente el mensaje con la clave pública del destinatario
- No requieren un intercambio previo de claves; el remitente puede actuar solo
- El descifrado solo es posible con la clave privada

HISTORIA

Los pioneros: Diffie y Hellman

-
- | | |
|-------------|--|
| 1965 | Whitfield Diffie se gradúa del MIT. Pensador independiente, no trabaja para ningún gobierno ni corporación |
|-------------|--|
-
- | | |
|-------------|--|
| 1969 | ARPANET comienza con cuatro sitios. Diffie anticipa computadoras universales, correo electrónico, pagos con tarjeta y el problema de privacidad asociado |
|-------------|--|
-
- | | |
|-------------|---|
| 1974 | Expone en el laboratorio Thomas Watson de IBM sobre ataques a la distribución de claves. El público se muestra escéptico y un criptógrafo menciona a un profesor de Stanford con la misma inquietud |
|-------------|---|
-
- | | |
|----------------------|---|
| Ese mismo día | Diffie atraviesa el país hasta Palo Alto para conocer a Martin Hellman. La colaboración produce el intercambio de claves Diffie-Hellman |
|----------------------|---|
-
- | | |
|-------------|---|
| 1982 | ARPANET da origen a Internet y el problema que resolvieron se convierte en un problema para todos |
|-------------|---|
-

EXPERIMENTO MENTAL

La caja con dos candados

1

Alice guarda el mensaje en una caja, la cierra con su candado y la envía. Conserva su llave.

2

Bob no puede abrirla. Agrega su propio candado y devuelve la caja.

3

Alice retira su candado. La caja permanece cerrada con el de Bob y vuelve a enviarla.

4

Solo queda el candado de Bob. Bob abre la caja y lee el mensaje.

Ninguna llave cambió de manos. La analogía no representa literalmente el algoritmo y la caja viaja dos veces, a diferencia de D-H, pero demuestra que el problema tiene solución.

LEA LA LETRA PEQUEÑA

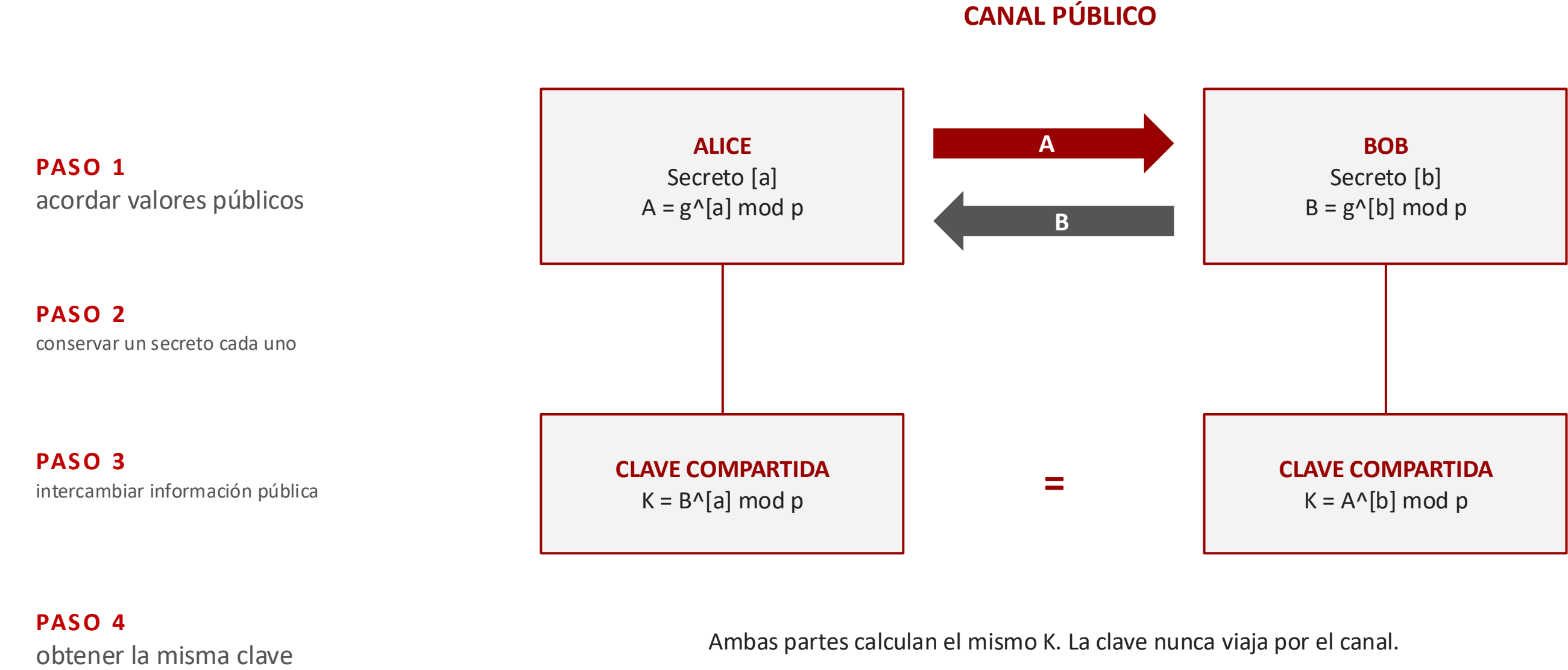
D-H no cifra información

- D-H solo determina una clave compartida [k] entre dos partes. Nunca transporta el mensaje
- El mensaje se cifra después mediante un algoritmo simétrico como AES
- Este es el patrón híbrido que reaparece en PGP y en los intercambios de claves de TLS

Algoritmo simétrico $E(D-H[k], M) = C$

D-H suministra la clave; AES, 3DES o IDEA proporciona la confidencialidad.

DIFFIE-HELLMAN



DIFFIE-HELLMAN

Un intercambio de claves explicado de manera sencilla

PASO 1

acordar valores públicos

Ambas partes acuerdan dos valores públicos. Cualquiera que observe la red puede verlos; eso es normal y esperado

PASO 2

conservar un secreto cada uno

Alice conserva un número privado y Bob conserva el suyo. Ninguno sale de su equipo

PASO 3

intercambiar información pública

Cada parte deriva un valor público a partir de su secreto y lo envía. Interceptar ambos valores no es suficiente

PASO 4

obtener la misma clave

Cada parte combina su secreto con el valor público de la otra y obtiene la misma clave compartida, que nunca se transmite

En el ejemplo reducido del libro, ambas partes obtienen por separado la clave 9. Lo importante no es el número, sino que la clave nunca se envió.

POR QUÉ FUNCIONA

Eve puede capturarlo todo y aun así queda por fuera

- Observa los valores públicos y la configuración pública. Es lo único que viaja
- Recuperar el número privado a partir del valor público corresponde a la dirección difícil de una operación unidireccional
- El orden de combinación no altera el resultado, por lo que ambas partes obtienen la misma clave sin compararla
- El intercambio no revela la clave. Registrar hoy el tráfico no ofrece una ventaja

Beneficio práctico

Una clave compartida nueva por sesión, acordada con alguien desconocido mediante un canal no confiable.

Lo que no proporciona

No demuestra quién está al otro extremo. La siguiente diapositiva aborda esa brecha.

LA IDEA UNIDIRECCIONAL

Sencilla en un sentido, inviable en el contrario

DIRECCIÓN DIRECTA

Calcular el valor público a partir de un secreto es rápido. Una máquina lo hace de inmediato

DIRECCIÓN INVERSA

Recuperar el secreto desde el valor público no tiene un atajo práctico con tamaños de clave reales

Por qué importa

Cada algoritmo de la sesión depende de una diferencia como esta. La seguridad no descansa en ocultar el método, que es público, sino en el costo de recorrer la dirección inversa.

Aclaración

La dificultad se asume, no se ha demostrado. Actualmente no se conoce un método eficiente, algo distinto de afirmar que sea imposible.

ATAQUE

Brecha crítica de D-H: ¿quién envió A?



- El paso 3 envía A y B en claro. Esa no es la debilidad. El problema consiste en que nada vincula A con Alice
- Con D-H por sí solo, Bob no puede asegurar que A proviene de Alice ni Alice que B proviene de Bob
- Existe un segundo riesgo relacionado con logaritmos discretos: el ataque de cumpleaños, que busca colisiones en el grupo cíclico

CASO ILUSTRATIVO

Un dígito, diez mil dólares

LO QUE ESCRIBIÓ ALICE

«Bob, transfiere \$10.000,00 a mi cuenta número 1234567».

cifrado con la clave D-H negociada por Eve → bu3fb3440r3nrunfjr3umi4gj57*je

LO QUE DESCIFRÓ BOB

«Bob, transfiere \$10.000,00 a mi cuenta número 3217654».

Bob descifró correctamente. La confidencialidad funcionó, pero el dinero llegó a Eve. El cifrado sin identidad no ofrece seguridad suficiente.

RSA

El algoritmo asimétrico de referencia

40+

años de vigencia

80%

del comercio mundial protegido

3

inventores del MIT: Rivest, Shamir y Adleman,
finales de la década de 1970

- Una mejora del candado: Alice envía copias de su candado abierto a todas las oficinas postales y conserva la única llave. Cualquiera puede cerrarlo; solo ella puede abrirlo
- El avance de Rivest, en abril de 1977, fue una función inversa de aritmética modular vinculada con la factorización
- Antecedentes: en 1997, CESG del Reino Unido atribuyó el cifrado de clave pública a James Ellis, 1970, y un esquema similar a RSA a Clifford Cocks, 1973

USO PRÁCTICO

Qué aporta RSA

UNA VEZ
generación de claves

RSA: CIFRADO Y DESCIFRADO

CADA MENSAJE
cifrado



AL RECIBIR
descifrado

PU = clave pública para cifrar
PR = clave privada para descifrar

GARANTÍA
asimetría

Este es el contrato operativo: publicar una clave, proteger la otra y evitar siempre que la clave privada viaje.

USO PRÁCTICO

Qué aporta RSA

UNA VEZ

generación de claves

Alice genera un par de claves. La parte pública puede publicarse en un directorio, un sitio web o una firma de correo

CADA MENSAJE

cifrado

Cualquier persona puede proteger un mensaje con la clave pública de Alice. Después, ni el remitente puede abrirlo para comprobarlo

AL RECIBIR

descifrado

Solo la clave privada de Alice lo abre. Si se pierde la clave, también se pierde el mensaje

GARANTÍA

asimetría

Derivar la clave pública desde la privada es sencillo; recorrer el camino inverso no lo es

Este es el contrato operativo: publicar una clave, proteger la otra y evitar siempre que la clave privada viaje.

DE EXTREMO A EXTREMO

Recorrido de un mensaje por el sistema

1
Bob Busca la clave pública de Alice. No existe contacto previo ni un secreto compartido

2
Bob Cifra el mensaje y envía el resultado. Desde ese momento no puede volver a leerlo

3
Alice Lo abre con su clave privada y recupera exactamente el mensaje original

Lo que observa un tercero

Un bloque de datos ininteligibles y una clave que ya es pública. Ninguno resulta útil.

Dónde falla en la práctica

Una clave privada copiada en un portátil, enviada por correo por comodidad o almacenada en un repositorio de código. En estos incidentes, las matemáticas rara vez constituyen el punto débil.

Referencia

El libro verifica el ciclo completo con números pequeños en la p. 104 para quien desee reproducirlo.

CRIPTOANÁLISIS

Dónde puede fallar RSA

- Ruta 1: factorizar N en $[p]$ y $[q]$. Actualmente no se conoce un algoritmo eficiente
- Ruta 2: conocimiento parcial. El atacante obtiene una cuarta parte de los dígitos de $[p]$ o $[q]$
- Ruta 3: computación cuántica. El algoritmo de Shor permitiría factorizar N en poco tiempo
- Ruta 4: parámetros inadecuados. Un mensaje muy corto con un exponente pequeño no alcanza a reducirse módulo N

Lectura práctica

Tres rutas dependen de matemáticas que no puede controlar. La cuarta depende de decisiones de implementación bajo su control.

Regla práctica

Los ataques que llegan a producción casi siempre explotan la implementación, no nuevos récords de factorización.

SEGURIDAD A LARGO PLAZO

Qué aporta realmente la longitud de clave

- No se conoce una forma eficiente de separar una clave pública en sus dos números primos. Los métodos publicados resultan inviables con tamaños reales
- La literatura describe métodos como la criba de campos numéricos, la criba cuadrática y Pollard, pero no permiten atacar una clave bien elegida
- El peligro aparece con el conocimiento parcial: si se filtra una fracción de uno de los primos, el resto puede recuperarse eficientemente
- Una futura computadora cuántica cambiaría el escenario. El libro remite al algoritmo de Shor y al capítulo 8

Lectura práctica

La longitud de clave protege frente al paso del tiempo y al avance del hardware. No protege una clave filtrada o mal generada.

Medida recomendada

Genere claves con una biblioteca validada en un equipo confiable y trate cualquier exposición parcial de la clave privada como una exposición total.

UNA FALLA REAL DE IMPLEMENTACIÓN

Por qué se filtran los mensajes cortos y el relleno es obligatorio

La falla

Si el mensaje es muy corto y el parámetro público es pequeño, el cifrado no alcanza a reducirse módulo N . El resultado puede invertirse con aritmética ordinaria, sin utilizar la clave.

- La entrada, no el algoritmo, causa la falla
- Ejemplos: PIN, respuesta de una palabra o indicador sí/no

SOLUCIÓN: RELLENO

Amplíe el mensaje con bits aleatorios antes de cifrar, de modo que cada texto cifrado utilice todo el módulo

Dos beneficios

El relleno elimina el atajo de los mensajes cortos. Como incorpora bits aleatorios, un mismo mensaje no produce dos veces el mismo texto cifrado.

Regla práctica

Nunca cifre directamente un valor corto. Use el modo con relleno proporcionado por la biblioteca y no lo implemente por cuenta propia.

MAPA DE ATAQUES

RSA tiene dos puertas

PUERTA 1: FACTORIZACIÓN DE N

La mayoría del criptoanálisis publicado se concentra aquí. Separar N en [p] y [q] permite obtener la clave privada [d]

PUERTA 2: POTENCIA DISCRETA $[M^E]$

Ataques sobre el exponente e, en gran medida por fuera del análisis convencional

- El libro presenta ataques no convencionales implementados por el autor entre 2011 y 2014 que recuperan [M] sin conocer [d], [p] ni [q]. Los detalla en el capítulo 6
- **NextPrime**, derivado del algoritmo genético de primos de Gerardo Iovane, resulta eficiente cuando [p] y [q] están a distancia polinómica, sin importar su tamaño
- Consecuencia: bajo esos métodos deja de cumplirse el supuesto de RSA según el cual el remitente nunca puede recuperar el mensaje

CASO DE ESTUDIO

Verificación de pruebas nucleares con RSA

Situación

La nación Alfa desea vigilar los datos sísmicos de la nación Beta para comprobar que no realice pruebas nucleares. Sensores ubicados en Beta registran y cifran los datos, que viajan por satélite hacia Alfa.

- Alfa necesita comprobar que Beta no modificó los datos
- Beta exige leer el mensaje antes de que salga de su territorio

CONFIGURACIÓN

Alfa elige $N = [p] \cdot [q]$ y e , envía (N, e) a Beta y mantiene $[d]$ en secreto

UBICACIÓN DE $[D]$

Dentro del software protegido del sensor enterrado que recopila los datos $[x]$

El cambio

Aquí RSA funciona en sentido inverso: la operación utiliza la clave privada $[d]$, no la pública e .

PROTOCOLO

Tres acciones en terreno

PASO 1
el sensor

Firma cada lectura con la clave privada almacenada en su software protegido. La lectura y la versión firmada viajan juntas

PASO 2
Beta verifica

Beta utiliza la clave pública para comprobar que la versión firmada corresponde a la lectura. Así puede leer todo antes de reenviarlo

PASO 3
Alfa verifica

Alfa ejecuta la misma verificación pública y acepta la lectura como auténtica

Una verificación pública satisface a dos partes que desconfían entre sí: Beta obtiene transparencia y Alfa obtiene integridad.

ANÁLISIS

Por qué funciona el protocolo invertido

- Solo quien posee $[d]$ puede producir un valor y cuya potencia e corresponda a un x válido
- Si Beta altera el sensor y cambia x , producir un y correspondiente vuelve a ser el problema difícil
- Modificar y , incluso conociendo x , presenta la misma complejidad que resolver el logaritmo discreto
- La comprobación utiliza aritmética pública. Cualquier persona que posea (N, e) puede ejecutarla

Lección general

Operar con la clave privada no oculta información: demuestra su origen. Eso hace una firma digital y allí comienza el capítulo 4.

PARALELO PRÁCTICO

Tiene la misma estructura de la firma de código y la atestación de firmware: el dispositivo firma y cualquier parte verifica

PRETTY GOOD PRIVACY

Uno de los programas criptográficos más utilizados

- Philip Zimmermann lo desarrolló durante la Guerra Fría para que él y sus amigos intercambiaran mensajes y archivos seguros por Internet
- Se publicó como código abierto y gratuito para usos no comerciales
- En esa época, los criptosistemas de más de 40 bits se trataban como municiones. PGP nunca utilizó claves menores de 128 bits
- El resultado fue un periodo de incertidumbre jurídica hasta que el gobierno de Estados Unidos cerró la investigación y lo exoneró

Vigencia regulatoria

Según el libro, patentar un criptosistema nuevo requiere autorización del Departamento de Defensa para publicarlo y las sanciones por incumplimiento son severas.

Por qué importa

La criptografía es una tecnología regulada. Las decisiones de despliegue tienen implicaciones jurídicas además de técnicas.

CIFRADO HÍBRIDO

PGP es un protocolo, no un algoritmo

PASO 1

transporte de la clave

un algoritmo asimétrico, como ElGamal o RSA, transporta la clave

PASO 2

clave de sesión

esa clave se convierte en la clave de sesión del cifrado simétrico: DES, hoy vulnerable, Triple DES, IDEA o AES

PASO 3

identidad

una firma digital identifica a los usuarios y bloquea el ataque de intermediario

PASO 4

entrega

el descifrado se realiza con la clave simétrica

La innovación consiste en combinar cifrado asimétrico para la clave y simétrico para los datos. Los canales seguros modernos, incluido TLS, siguen esta estructura.

Bertaccini (2024), cap. 3, pp. 112-113; firmas en el cap. 4.

ELGAMAL

Una versión asimétrica de Diffie-Hellman

- Se diseñó para resolver dos brechas de D-H: el ataque de intermediario y la imposibilidad de firmar la propiedad de una clave
- Al igual que RSA, es un algoritmo asimétrico: cifra el mensaje sin intercambiar primero una clave
- Introduce un nuevo elemento: un número entero aleatorio $[k]$, elegido por el remitente y mantenido en secreto
- $[k]$ hace efímero el cifrado. El mismo mensaje se cifra de forma diferente en cada ocasión

DÓNDE SE UTILIZA

El cifrado ElGamal se utiliza en GNU Privacy Guard (GnuPG), software libre de referencia para comunicaciones privadas y firmas digitales

Adelanto

La aleatoriedad efímera reaparece en los protocolos de conocimiento cero del capítulo 5.

USO PRÁCTICO

ElGamal: un valor aleatorio nuevo para cada mensaje

UNA VEZ claves

Cada parte publica una clave pública y conserva una privada, igual que en RSA

POR MENSAJE valor efímero

El remitente genera un número aleatorio nuevo, lo utiliza una sola vez y lo mantiene en secreto

AL RECIBIR descifrado

La clave privada del destinatario elimina el enmascaramiento y recupera el mensaje

Importancia del valor aleatorio

Al cifrar dos veces el mismo mensaje se obtienen textos cifrados diferentes. Un observador no puede identificar la repetición, propiedad que RSA obtiene mediante el relleno.

Regla operativa

Utilice el valor aleatorio una sola vez y no lo almacene. Su reutilización constituye una causa clásica de fallas en esta familia.

Dónde se utiliza

GnuPG, software libre de referencia para comunicaciones privadas y firmas digitales.

CRIPTOANÁLISIS

ElGamal se apoya en dos problemas difíciles

LOGARITMO DISCRETO

Todos los valores públicos son potencias discretas: $B \equiv g^b$, $y_1 \equiv g^k$, $Kb \equiv y_1^b \pmod{p}$

FACTORIZACIÓN

$y_2 \equiv [M] \cdot B^k \pmod{p}$ es un producto. Si $H \equiv B^k$, entonces $y_2 \equiv M \cdot H$ y $M \equiv y_2/H$

Consecuencia práctica

Al factorizar y_2 probablemente se obtiene $[M]$. La seguridad no depende únicamente del logaritmo discreto.

Regla operativa

Nunca reutilice $[k]$. Su valor reside en ser impredecible y utilizarse una sola vez.

SÍNTESIS DEL CAPÍTULO 3

Cuatro herramientas, cuatro funciones

Diffie-Hellman

Acuerda una clave compartida

Sin firma ni defensa frente al ataque de intermediario

Intercambio de clave antes del cifrado simétrico

RSA

Cifra y firma

Factorización, mensajes y exponentes cortos; requiere relleno

Propósito general; cerca del 80 % del tráfico comercial

PGP

Protege tráfico real

Depende de sus componentes

Protocolo híbrido: clave asimétrica y datos cifrados simétricamente

ElGamal

Cifra con un valor [k] efímero

Logaritmo discreto y factorización de y^2

GnuPG y firmas

Ninguna herramienta responde por sí sola «¿quién envió esto?». Esa respuesta requiere funciones hash y firmas.

02

CAPÍTULO 4

Funciones hash y firma digital

Funciones hash · SHA-1 · firmas RSA y ElGamal · firmas ciegas

EL PROBLEMA

Firmar un contrato que no puede mostrar

- En papel, ambas partes se encuentran en la misma sala y un notario garantiza sus identidades
- En línea, los firmantes con frecuencia no se conocen, intercambian documentos por correo y carecen de un tercero confiable
- Existen dos necesidades simultáneas: verificar la firma y ocultar el contenido frente a observadores

Qué debe demostrar una firma digital

Identidad del remitente · integridad de [M] · no repudio

Ruta del capítulo

Funciones hash → firmas digitales con RSA y ElGamal → firmas ciegas.

DEFINICIÓN

Una función hash produce una salida de tamaño fijo

El término

hash significa reducir en fragmentos. Una entrada $[M]$ de cualquier longitud ingresa a $f(H)$ y produce un resumen (M) de tamaño fijo.

- Es una función unidireccional: sencilla en la dirección directa y muy difícil o imposible en la inversa
- Todo el contenido de Wikipedia produce un valor con la misma longitud fija que un mensaje de una sola línea

MODELO MENTAL

Un embudo triturador: entra texto plano y sale un resumen de longitud fija

OPUESTO A LA EXPANSIÓN DE BITS

Las funciones de expansión aumentan la entrada; las funciones hash la reducen

Notación utilizada en el libro

$f(H)$ o $h[M]$ para la función hash, y (M) o (m) para el resumen.

PROPIEDADES

Tres propiedades y el beneficio de cada una

1 · CÁLCULO DIRECTO RÁPIDO

Dado $[M]$, el resumen $h(M)$ se calcula con rapidez

2 · PRÁCTICAMENTE IRREVERSIBLE

Volver desde el resumen (M) hasta $[M]$ debe resultar prácticamente imposible

3 · RESISTENCIA A COLISIONES

Encontrar $[m1] \neq [m2]$ tales que $h(m1) = h(m2)$ debe ser computacionalmente inviable

Por qué la tercera propiedad es decisiva

Una colisión permite sustituir documentos bajo una misma firma. La seguridad de la firma y la resistencia a colisiones reflejan la misma propiedad desde dos perspectivas.

APLICACIONES

Dónde aportan valor las funciones hash

- **Firma sin exposición:** se firma el resumen (M) como representación de [M]
- **Integridad:** al cambiar un bit de una enciclopedia, el resumen cambia por completo
- **Indexación de bases de datos,** incluido el motor de búsqueda criptográfica del capítulo 9
- **Prueba de trabajo:** la minería de Bitcoin utiliza SHA-256

Bitcoin, en concreto

Los mineros agrupan cerca de un megabyte de transacciones como entrada de SHA-256 y buscan una salida aceptada por la red. Quien la encuentra primero obtiene la recompensa.

Nota cuántica

Las funciones hash son candidatas a ofrecer resistencia cuántica bajo determinadas condiciones, como explica el capítulo 8.

PANORAMA

Funciones hash relevantes

MD5

Puede utilizarse para experimentar, pero la familia MD se considera insegura debido a ataques de colisión basados en análisis diferencial

FAMILIA SHA

Desarrollada por la NSA. SHA-1 es el caso de estudio; SHA-2 y SHA-3 son sus sucesores, y SHA-256 se utiliza en Bitcoin

CRC32

Algoritmo común que el libro incluye entre las funciones de resumen importantes

RIPEMD-160

Desarrollada por científicos europeos a comienzos de la década de 1990, con versiones de 160, 256 y 320 bits. No se ha quebrado, pero no alcanzó la adopción de SHA

Una función unidireccional lenta, como el logaritmo discreto, también cumpliría la definición, pero sería demasiado lenta y débil para utilizarse como hash en la práctica.

SELECCIÓN DE UNA FUNCIÓN HASH

Qué función utilizar y cuál retirar

RETIRADAS

MD5 y la familia MD se consideran inseguras porque existen ataques prácticos de colisión. SHA-1 se considera insegura desde 2005

ACTUALES

SHA-2 y SHA-3 son las familias sucesoras. La prueba de trabajo de Bitcoin utiliza SHA-256

OTRAS OPCIONES

RIPEMD-160, desarrollada por investigadores europeos a comienzos de la década de 1990, cuenta con versiones de 160, 256 y 320 bits. No se ha quebrado, pero su adopción ha sido limitada

Por qué no crear una función propia

Las funciones hash combinan rotaciones, desplazamientos y sumas de bits sobre constantes elegidas para evitar colisiones. Modificarlas puede introducir debilidades. Utilice el estándar sin alteraciones.

FUNCIÓN PRÁCTICA

Qué hace una función hash con un archivo

- Cualquier entrada, como una palabra, un contrato o una imagen de disco, produce una huella de longitud fija
- **Determinismo: la misma entrada siempre produce la misma huella, sin importar la máquina o la herramienta**
- **Efecto avalancha: cambiar un solo bit modifica por completo la huella**
- **Unidireccionalidad: la huella no revela el contenido del cual proviene**
- **Rapidez: permite procesar gigabytes con un costo razonable, lo que hace viables las verificaciones de integridad**

Para qué se utiliza

Permite verificar una descarga, detectar alteraciones en tránsito, indexar registros y firmar un documento sin exponerlo.

Qué no es

No es cifrado porque no existe nada que descifrar. Tampoco comprime información: el contenido desaparece y solo permanece la huella.

PRUÉBELO

Misma entrada, misma huella

Prueba clásica

Calcule SHA-1 sobre las tres letras abc con cualquier herramienta, como una terminal, un sitio web o una biblioteca. Obtendrá el mismo valor de 160 bits impreso en el libro.

A9993E36 4706816A BA3E2571 7850C26C 9CD0D89D

Cambie una letra y repita el cálculo. El nuevo valor no se parecerá al anterior.

Valor didáctico del ejercicio

El determinismo permite verificar y el efecto avalancha permite detectar alteraciones. Ambos se observan en treinta segundos desde una terminal.

Advertencia

SHA-1 se utiliza aquí únicamente con fines didácticos y se considera insegura desde 2005. Repita el ejercicio con SHA-256 para adquirir una práctica vigente.

AUTENTICACIÓN

Qué puede demostrarse y qué todavía puede fallar

TRES FACTORES CLÁSICOS

Algo que el usuario sabe, como una contraseña · posee, como una tarjeta o token · es, como una huella, iris o rasgo biométrico

UN CUARTO FACTOR DEL LIBRO

Ondas cerebrales: el patrón activado al observar o pensar en una imagen es único. Brain Password permite desbloquear dispositivos y aplicaciones, capítulo 6

- Autenticación: ¿cómo puede Bob comprobar que el mensaje proviene de Alice?
- No repudio: Alice podría negar posteriormente haber sido la remitente
- Integridad: un atacante intermediario podría modificar parte del contenido
- Espionaje: el mensaje se lee sin modificarlo. El libro muestra que puede ocurrir incluso sin la clave, capítulo 6

FIRMA EN LA PRÁCTICA

Cómo se realizan la firma y la verificación

REMITENTE
firma

Genera una firma sobre el documento con su propia clave privada, la clave opuesta a la utilizada para cifrar

REMITENTE
envía

Transmite juntos el documento cifrado y la firma

CUALQUIER PARTE
verifica

Utiliza la clave pública del remitente para confirmar que la firma solo pudo generarse con la clave privada correspondiente

DESTINATARIO
acepta

Una firma válida demuestra identidad, integridad y no repudio

Mantenga claras ambas direcciones: cifre con la clave pública del destinatario y firme con su propia clave privada. Cuando se ejecutan ambas operaciones intervienen dos pares de claves.

Bertaccini (2024), cap. 4, Firmas digitales RSA, pp. 139-140.

EN TRÁNSITO

Qué se transmite realmente

EL PAR

El documento cifrado y la firma viajan juntos. Uno protege el contenido y la otra protege la identidad

EN EL DESTINO

La destinataria abre el documento con su clave privada y verifica la firma con la clave pública del remitente. Son dos operaciones independientes con garantías distintas

La limitación

Cualquier persona que posea la clave pública del remitente puede verificar. Eso es intencional, pero implica que aquello que se firmó puede ser recuperable por todos.

La regla resultante

Nunca firme directamente el documento. La siguiente diapositiva contiene la idea esencial.

Referencia

El libro desarrolla el ciclo completo con números pequeños en las pp. 140-141.

HÁBITO CRÍTICO

Nunca firme el mensaje: firme su hash

Falla del ejemplo anterior

(S, e, Nb) son públicos. Cualquier persona puede resolver $S^e \equiv x \pmod{Nb}$ y recuperar $[M]$. Firmar el texto plano expone el propio texto plano.

$$S^e \equiv x \pmod{Nb} \rightarrow x = [M]$$

SOLUCIÓN

Bob calcula $h[M] = (m)$, firma (m) y envía el par (c, S)

VERIFICACIÓN

Alice ya descifró $[M]$, por lo que puede comprobar $h[M] = m$. VERDADERO valida a Bob; FALSO rechaza su afirmación de identidad

Regla para recordar

La firma debe poder verificarse públicamente y el mensaje debe ser legible solo para su destinatario. El hash permite separar ambas propiedades.

ANÁLISIS

Cómo se detecta una firma falsificada

- Un atacante distinto de Bob debe resolver $m^{[db]} \equiv S \pmod{Nb}$ para obtener $[db]$, un problema de logaritmo discreto
- Conocer el par (m, S) no ayuda. $[db]$ continúa fuera de alcance
- Eve sustituye $[db]$ por (de) y genera una firma falsa S : $m^{(de)} \equiv S \pmod{Nb}$
- La comprobación de Alice obtiene un valor diferente. Los hashes no coinciden, por lo que rechaza la firma y no abre información proveniente de esa dirección

Por qué las colisiones son críticas

La defensa depende de que una firma diferente produzca un hash distinto. Una colisión elimina esa diferencia, razón por la cual se vigila cuidadosamente esta propiedad.

Adelanto

El libro describe este mecanismo como un recurso sencillo y presenta ataques no convencionales más sofisticados en el capítulo 6.

LA OTRA FAMILIA

Firmas ElGamal: misma disciplina, mecánica diferente

- El firmante trabaja con la huella del documento, nunca con el documento directamente
- La verificación compara dos valores calculados en lugar de recuperar el mensaje, una diferencia estructural frente a RSA
- La firma incorpora un valor aleatorio nuevo y de un solo uso, igual que el cifrado ElGamal
- La seguridad depende de la misma diferencia unidireccional y de una segunda debilidad que el libro identifica en el enmascaramiento

Idea esencial

El algoritmo cambia, pero la disciplina se mantiene: firmar la huella, proteger la clave privada y no reutilizar el valor aleatorio.

Dónde se utiliza

Firmas de GnuPG, la misma familia de herramientas utilizada para firmar versiones de software y correos.

FIRMAS CIEGAS

Firmar aquello que no puede leerse

- David Chaum inventó las firmas ciegas. Su artículo de 1982 se titula **Blind Signatures for Untraceable Payments**
- En 1990 fundó eCash, una moneda no rastreable. El proyecto quebró en 1998
- Se le reconoce como uno de los padres del dinero digital, junto con Bitcoin
- Objetivos: impedir el doble gasto y mantener seguros y anónimos los pagos electrónicos

CASO 1 · PRIORIDAD

Registrar una invención sin revelar sus detalles

CASO 2 · VOTACIÓN

El receptor debe leer el voto, pero la identidad del votante debe permanecer secreta

Definición

Firmar a ciegas significa firmar algo sin conocer su contenido.

PROTOCOLO

Cegar, firmar y revelar

PASO 1
solicitante

Enmascara el documento con un valor aleatorio propio y envía únicamente la versión enmascarada

PASO 2
firmante

Firma lo que recibe. No puede ver el documento ni retirar el enmascaramiento

PASO 3
solicitante

Retira su propio enmascaramiento y obtiene una firma válida sobre el documento original

RESULTADO
garantía

Cualquier persona puede verificar posteriormente la firma, aunque el firmante nunca conoció el contenido firmado

Este mecanismo sustenta el efectivo digital anónimo y las votaciones anónimas: la autoridad certifica sin observar el contenido.

USOS Y RIESGOS

Potente y fácil de utilizar incorrectamente

PAGOS ANÓNIMOS

Objetivo original de Chaum: impedir el doble gasto y conservar el anonimato del pagador. eCash, fundado en 1990, fue un intento de implementarlo

VOTACIÓN ELECTRÓNICA

El voto debe contabilizarse y la identidad del votante debe permanecer desconocida

PRIORIDAD SIN DIVULGACIÓN

Registrar una invención ahora y revelar sus detalles posteriormente

El peligro

El firmante desconoce lo que firma. Bob podría hacerle firmar un cheque por un millón de dólares. La firma ciega requiere reglas estrictas, externas al protocolo, sobre las clases de documentos permitidas.

Superficie de ataque

El paso de enmascaramiento es un producto, por lo que un atacante puede intentar operar directamente sobre él sin recuperar el valor aleatorio.

CIERRE

Cinco ideas esenciales de la sesión

- El cifrado asimétrico permite acordar un secreto con alguien a quien nunca se ha conocido
- **Diffie-Hellman acuerda una clave; RSA y ElGamal cifran y permiten construir firmas**
- Las rupturas reales suelen explotar mensajes o exponentes cortos, ausencia de relleno y reutilización de valores aleatorios
- PGP y TLS aplican un patrón híbrido: cifrado asimétrico para la clave, simétrico para los datos y firma para la identidad
- **Firme el hash, nunca el mensaje. Firmar directamente puede exponer el secreto que debía proteger**

Fuente de la presentación: Massimo Bertaccini, Cryptography Algorithms, 2.^a edición (acceso anticipado), Packt Publishing, 2024, capítulo 3, Asymmetric Encryption, pp. 89-116, y capítulo 4, Hash Functions and Digital Signature, pp. 117-148. Las referencias a los capítulos 5-9 pertenecen al libro.